



PDF Download
3639478.3643065.pdf
11 March 2026
Total Citations: 51
Total Downloads: 1403

Latest updates: <https://dl.acm.org/doi/10.1145/3639478.3643065>

SHORT-PAPER

Prompt-Enhanced Software Vulnerability Detection Using ChatGPT

CHENYUAN ZHANG, Xiamen University, Xiamen, Fujian, China

HAO LIU, Xiamen University, Xiamen, Fujian, China

JIUTIAN ZENG, Alibaba Group Holding Limited, Hangzhou, Zhejiang, China

KEJING YANG, Alibaba Group Holding Limited, Hangzhou, Zhejiang, China

YUHONG LI, Alibaba Group Holding Limited, Hangzhou, Zhejiang, China

HUI LI, Xiamen University, Xiamen, Fujian, China

Open Access Support provided by:

Alibaba Group Holding Limited

Xiamen University

Published: 23 May 2024

Citation in BibTeX format

ICSE-Companion '24: 2024 IEEE/ACM
46th International Conference on
Software Engineering: Companion
Proceedings
April 14 - 20, 2024
Lisbon, Portugal

Conference Sponsors:
SIGSOFT

Prompt-Enhanced Software Vulnerability Detection Using ChatGPT

Chenyuan Zhang*

Key Laboratory of Multimedia Trusted Perception and
Efficient Computing, Ministry of Education of China,
School of Informatics, Xiamen University
China
zhangchenyuan@stu.xmu.edu.cn

Hao Liu*

Key Laboratory of Multimedia Trusted Perception and
Efficient Computing, Ministry of Education of China,
School of Informatics, Xiamen University
China
haoliu@stu.xmu.edu.cn

Jiutian Zeng

Kejing Yang

Yuhong Li

Alibaba

China

{zengjiutian.zjt, kejing.ykj, daniel.lyh}@alibaba-inc.com

Hui Li†

Key Laboratory of Multimedia Trusted Perception and
Efficient Computing, Ministry of Education of China,
School of Informatics, Xiamen University
China
hui@xmu.edu.cn

ABSTRACT

With the increase in software vulnerabilities that cause significant economic and social losses, automatic vulnerability detection has become essential in software development and maintenance. Recently, large language models (LLMs) have received considerable attention due to their stunning intelligence, and some studies consider using ChatGPT for vulnerability detection. However, they do not fully consider the characteristics of LLMs, since their designed questions to ChatGPT are simple without a prompt design tailored for vulnerability detection. This paper launches a study on the performance of software vulnerability detection using ChatGPT with different prompt designs. Firstly, we complement previous work by applying various improvements to the basic prompt. Moreover, we incorporate structural and sequential auxiliary information to improve the prompt design. Moreover, we leverage ChatGPT's ability of memorizing multi-round dialogue to design suitable prompts for vulnerability detection. We conduct extensive experiments on two vulnerability datasets to demonstrate the effectiveness of prompt-enhanced vulnerability detection using ChatGPT.

KEYWORDS

software vulnerability detection, prompt engineering, large language model, chatgpt

ACM Reference Format:

Chenyuan Zhang, Hao Liu, Jiutian Zeng, Kejing Yang, Yuhong Li, and Hui Li. 2024. Prompt-Enhanced Software Vulnerability Detection Using ChatGPT.

*The first two authors contributed equally.

†Corresponding author.

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for components of this work owned by others than the author(s) must be honored. Abstracting with credit is permitted. To copy otherwise, or republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee. Request permissions from permissions@acm.org.

ICSE-Companion '24, April 14–20, 2024, Lisbon, Portugal

© 2024 Copyright held by the owner/author(s). Publication rights licensed to ACM.

ACM ISBN 979-8-4007-0502-1/24/04...\$15.00

<https://doi.org/10.1145/3639478.3643065>

In 2024 IEEE/ACM 46th International Conference on Software Engineering: Companion Proceedings (ICSE-Companion '24), April 14–20, 2024, Lisbon, Portugal. ACM, New York, NY, USA, 2 pages. <https://doi.org/10.1145/3639478.3643065>

1 INTRODUCTION

An increasing number of software vulnerabilities are causing significant economic and social losses, making vulnerability detection a hotspot [2]. Traditional vulnerability detection approaches are mainly based on rules and classical machine learning techniques. These methods rely either on highly expert knowledge or on coarse-grained patterns of vulnerabilities, and they cannot achieve accurate vulnerability detection. Recent deep-learning-based approaches are not general detection methods, as they are programming-language-specific or vulnerable-type-specific. With the rapid development of large language models (LLMs), a few works have considered using ChatGPT to improve software vulnerability detection [1, 2]. Nevertheless, these methods do not fully consider the characteristics of LLMs, since their designed questions to ChatGPT are simple without a prompt design tailored for vulnerability detection.

This paper¹ launches a study on vulnerability detection using ChatGPT 4 with different prompt designs. We complement various prompts to the basic prompts, including adding structural and sequential auxiliary information of the source code, and designed chain-of-thought prompting to investigate the vulnerability detection capabilities of ChatGPT on our collected vulnerability datasets covering **two programming languages**.

2 PROMPT DESIGNS

Firstly, based on the basic prompt (i.e., simply ask ChatGPT whether the input code contains vulnerabilities), we add structural and sequential auxiliary information such as DFG and API call sequences, and the improved prompts are:

¹More details are available in our technical report: <https://arxiv.org/abs/2308.12697>.

Table 1: Performance of different vulnerability detection methods. Best results are shown in bold.

	Java									C/C++								
	Vulnerable				Non-Vulnerable				All	Vulnerable				Non-Vulnerable				All
Prompt	P	R	F1	Det.	P	R	F1	Det.	Acc	P	R	F1	Det.	P	R	F1	Det.	Acc
CFGNN	0.831	0.144	0.245	143/995	0.383	0.948	0.546	529/558	0.437	1.000	0.105	0.191	2/19	0.393	1.000	0.564	11/11	0.433
Bugram	0.469	0.032	0.061	38/1171	0.435	0.953	0.598	874/917	0.436	0.507	0.514	0.51	511/995	0.459	0.453	0.456	411/908	0.484
P _{api}	0.894	0.622	0.734	728/1171	0.652	0.906	0.759	831/917	0.747	0.521	0.758	0.618	646/852	0.490	0.250	0.331	198/791	0.514
P _{dfg}	0.784	0.564	0.656	661/1171	0.590	0.802	0.680	735/917	0.669	0.525	0.970	0.682	985/1015	0.516	0.035	0.065	32/922	0.525
P _{chain}	0.668	0.93	0.777	1089/1171	0.821	0.409	0.546	375/917	0.701	0.675	0.973	0.797	988/1015	0.943	0.485	0.640	447/922	0.741

I want you to act as a vulnerability detection system. I will provide you with the original program and the data flow information/API call sequence, and you will act upon them. [DF description]/[API description]. Is the following program buggy? [CODE]. Please answer Yes or No.

where [DF description] and [API description] are constructed based on the extracted DFGs and API call sequences of the input code ([CODE]), respectively. We design templates for [DF description] and [API description] to integrate them into the prompt:

[DFG description]: The data value of the variable v_i at the p_i th token comes from/is computed by the variable v_j at the p_j th token.

[API description]: The program first calls a_1 , then calls a_2 , ..., then calls a_i , ..., and finally calls a_n .

Moreover, since ChatGPT can memorize multi-step interactions, we attempt chain-of-thought prompting for vulnerability detection. We design the first-step prompt for the intention of the test code:

P₁^(chain): Please describe the intent of the given code [CODE].

Following the first step, we continue to ask ChatGPT about the vulnerability of the test function.

P₂^(chain): I want you to act as a vulnerability detection system. Is the above program buggy? Please answer Yes or No.

The motivation of the two-step prompt is to remind ChatGPT to first analyze the functionality of the code before detecting the vulnerability so that it does not simply guess the vulnerability without understanding the code.

3 EXPERIMENTS

We compared ChatGPT with two state-of-the-art vulnerability detection methods CFGNN [4] and Bugram [3] on our two collected vulnerability datasets covering Java and C/C++ programs. CFGNN is a condition-based vulnerability detection method, and Bugram adopts n-gram language models instead of rules to detect vulnerabilities. We use Accuracy (Acc), Precision (P), Recall (R) and F1 score (F1) as evaluation metrics.

Overall Performance. Tab. 1 illustrates the results. We report the performance on the vulnerable sample set and the non-vulnerable sample set separately. We also provide the results on the complete sample set which are denoted by “All” in Tab. 1. In Tab. 1, “Det.” denotes how many test samples are correctly predicted. We can see that, compared to two baselines, ChatGPT (P_{dfg}, P_{apt} and P_{chain}) shows better performance on vulnerability detection w.r.t. both accuracy and coverage.

Usefulness of Auxiliary Information. Next, we investigate the impact of incorporating auxiliary information in the prompt. From Tab. 1, We can see that, on the Java dataset, adding API calls to the prompt (P_{apt}) results in an accuracy of 0.747. On the C/C++ dataset, the prompt including data flow information P_{dfg} works best. Our results show that different auxiliary information has diverse effects on different programming languages: (1) Incorporating API calls is more effective for detecting vulnerability in Java programs. (2) Including data flow information contributes a little to the understanding of C/C++ vulnerable programs.

Effectiveness of Chain-of-Thought Prompting. Tab. 1 shows that chain-of-thought prompting (P_{chain}) has different effects on Java and C/C++ datasets. It provides a great improvement on C/C++ dataset but degrades the detection performance on Java dataset. Overall, it achieves good accuracy on both Java and C/C++ dataset.

4 CONCLUSION

In this paper, we study the ability of prompt-enhanced ChatGPT in software vulnerability detection, an important task to ensure the security of software. In particular, we design several prompts that are tailored for vulnerability detection, including adding extra information (i.e., data flow information and API calls) and leveraging chain-of-thought prompting. We conduct extensive experiments on two vulnerability datasets to demonstrate the effectiveness of prompt-enhanced vulnerability detection using ChatGPT. In the further, we will explore more advanced technology like fine-tuning LLMs for vulnerability detection.

REFERENCES

- [1] Jialun Cao, Meiziniu Li, Ming Wen, and Shing-Chi Cheung. 2023. A study on Prompt Design, Advantages and Limitations of ChatGPT for Deep Learning Program Repair. *arXiv Preprint* (2023). <https://arxiv.org/abs/2304.08191>
- [2] Dominik Sobania, Martin Briesch, Carol Hanna, and Justyna Petke. 2023. An Analysis of the Automatic Bug Fixing Performance of ChatGPT. *arXiv Preprint* (2023). <https://arxiv.org/abs/2301.08653>
- [3] Song Wang, Devin Chollak, Dana Movshovitz-Attias, and Lin Tan. 2016. Bugram: bug detection with n-gram language models. In *ASE*, 708–719.
- [4] Jian Zhang, Xu Wang, Hongyu Zhang, Hailong Sun, Xudong Liu, Chunming Hu, and Yang Liu. 2023. Detecting Condition-Related Bugs with Control Flow Graph Neural Network. In *ISSTA*. 1370–1382.